Hunting on the Cheap

Jamie Butler, CTO
Andrew Morris, Threat Researcher
Anjum Ahuja, Threat Researcher

ENDGAME.

About US

Jamie Butler

- CTO @ Endgame
- Security Researcher
- james.butler@endgame.com

Anjum Ahuja

- Threat Researcher @ Endgame
- Network Security & Machine Learning
- aahuja@endgame.com

Andrew Morris

- Threat Researcher @ Endgame
- Offense Ops & Pentesting
- amorris@endgame.com
- @andrew___morris

Agenda

- Threat Hunting
- Hunt Cycle
- Hunting on the Cheap
  - Hunting on Network
  - Hunting on Host
  - Hunting with Intelligence
- Conclusion

Adversary Hunting

- Assume breach
- Finding and eliminating badness that already exists in your network
- Mature organizations
- Interesting marriage between offense and defense

Hunting … on the cheap

- You can Hunt!
  - Free tools
  - Effective Techniques
  - With or without sources of commercial threat intelligence
- Try it before you buy it

Cool – So how do I hunt on the cheap?

- Look at your network and your hosts
- General Hunt methodology
  - Collect data
  - Analyze collection – outliers and indications of bad
  - Follow up on leads
  - Remediate
  - Repeat
- We will discuss specific places to look and what to look for in the data
  - Network
  - Host

Hunting on the Network

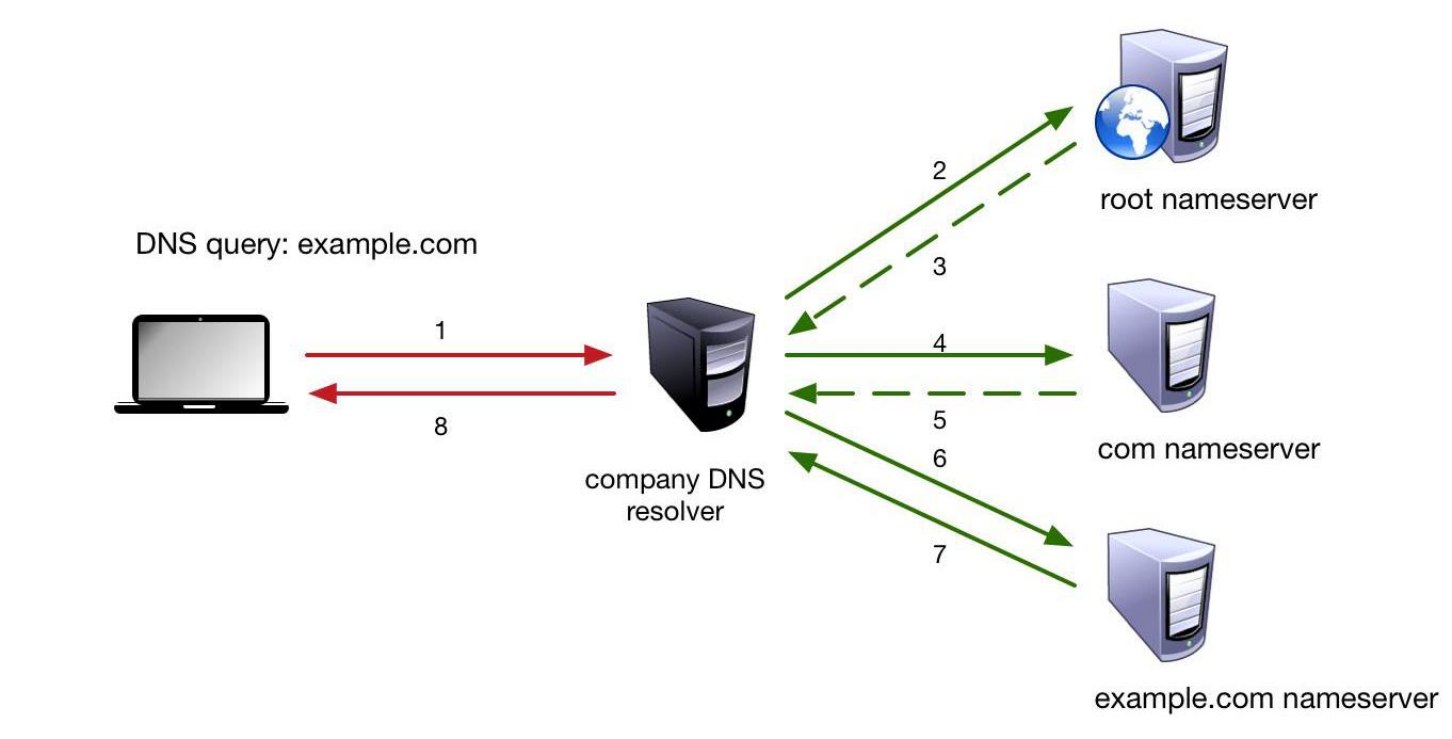
…on the cheap

Why Hunt on the Network

- Known bad network IOCs are short-lived
  - IPs change - SAAS has made it easier to migrate to new infrastructure
  - Domains change - Domain registration has gotten simpler (little or no validation), cheaper (tons of new TLDs) and stealthy (WHOIS privacy service)
- Instead, find unknown bad from higher order signals and patterns

Passive DNS

"Passively observe inter-server DNS messages and reassemble DNS transactions"



Passive DNS

- passiveDNS (https://github.com/gamelinux/passivedns)
- sie-dns-sensor (https://github.com/farsightsec/sie-dns-sensor)


```
{u'answers': [{u'rdata': u'216.58.219.14',
               u'rname': u'google.com.',
               u'rtype': 1,
               u'ttl': 300}],
 u'dst_ip': 'redacted',
 u'qname': [u'google.com.'],
 u'qtype': 1,
 u'rcode': 0,
 u'src_ip': 'redacted',
 u'time': 1457542366}
```


Fields	Interesting values
record type	A(1), AAAA(28), NS(2), CNAME(5), MX(15)
return code	NOERR(0) SERVFAIL(2) NXDOMAIN(3)

Workflow

- Discover what's normal
- Hunt for outliers
  - Fast flux
  - Domain Generation Algorithm (DGA)
  - NXDOMAIN
  - Periodicity
  - Phishing detection
- Validate & IR

Whitelist

Friendly neighborhood whitelist - Alexa top domains

- Alexa tracks popularity of websites
    - From browser’s address bar
    - Doesn’t include all the media and third party content requested by the main page
- PassiveDNS captures queries from all applications, of all record types, even failures and unsolicited responses

Dynamic DNS domains

Dynamic dns domain	Alexa rank
sytes.net	14,424
zapto.org	64,151
hopto.org	60,658
dynu.com	108,459
redirectme.net	159,783
servehttp.com	207,700
serveftp.com	465,177

```
subdomains = rdd.map((registered_domain(get_rname), get_rname))
mean = numpy.mean(subdomains.distinct().countByKey().values())
outliers = subdomains.filter(num_subdomains > mean).collect()
outliers = {domain:map(whois_ip, ips) for domain, ips in outliers}
dynamic_dns = {domain for domain, whois_records in outliers if is_diverse(whois_records)}
```

Fast Flux

"Large number of IPs associated with a single domain that are swapped in and out at high frequency"

- Load balancers also do the same
- Anycast looks similar
- But, diversity of the IP address space separates the two classes

```
A_records = rdd.map((get_rname, get_rdata) if rtype in set(['A', 'AAAA']))
mean = numpy.mean(A_records.distinct().countByKey().values())
outliers = A_records.filter(num_A_records > mean).collect()
outliers = {domain:map(whois_ip, ips) for domain, ips in outliers}
confirmed_outliers = {domain for domain, whois_records in outliers if is_diverse(whois_records)}
```

Fast flux (benign)

Domain	# IPs	Owner of IP space
prod-w.nexus.live.com.akadns.net.	21	microsoft informatica ltda, microsoft corp, microsoft corporation
www-google-analytics.l.google.com.	26	google inc
sync.teads.tv.	21	amazon.com inc, amazon technologies inc, amazon data services ireland limited
prodlb01-1956114858.eu-west-1.elb.amazonaws.com.	19	amazon data services ireland ltd, amazon web services, elastic compute cloud ec2 eu, amazon.com inc, amazon technologies inc, dub5 ec2
ap.gslb.spotify.com.	25	spotify ltd, spotify ab
profile.ess-apple.com.akadns.net.	23	apple inc

Fast Flux (malicious)

Domain	# IPs	CC distribution	Owner of IP space
ahmdallame.no-ip.biz	34	iq,fr	dynamic ip pool, earthlink ltd. Communications & internet services
liiion999.zapto.org	45	fr, ma, it, us, hu, at, ro, mx	edis infrastructure in france, mexico server, telentia enterprise customer, amplusnet srl, micfo llc., serverastra kft, india server, dynamic ip pool, adsl_maroc_telecom, psinet inc, national computer systems co
liiion777.zapto.org	50	fr, ma, us, hu, at, nl, ro, mx	dynamic ip pool, mexico server, maroctelecomasdl, edis infrastructure in spain, telentia enterprise customer, amplusnet srl, serverastra kft., india server, leaseweb netherlands b.v., adsl_maroc_telecom,psinet inc.

False positive *.pool.ntp.org also hosted on diverse IP address space

DGA

"Algorithmically generate large number of domain names, to serve as C&C servers"

- Thousands of potential domains per day
- Botnet controller only needs to register one of them to keep the lights on

DGA - Features

- Features
  - Entropy
  - Length
  - Vowel to Consonant ratio
  - Longest consonant sequence
  - ngrams from Alexa top domains 2LDs
  - ngrams from English dictionary
- RandomForestClassifier

DGA (True positives)

Cryptolocker (96.4% accuracy)	Verdict	Confidence
vobrbjlloae.fr	DGA	0.92
sgnuqrek.uk	DGA	0.84
dkoudkavtnjc.tf	DGA	0.97
kspruxe.uk	DGA	0.62
qalhanhhsockuxj.yt	DGA	0.96
wtjawjv.nl	DGA	0.64

Tiny Banker (98.2% accuracy)	Verdict	Confidence
sdprjrntgvlw.ru	DGA	0.98
fnetiyouqksr.xyz	DGA	0.96
cpowrnbskkxt.xyz	DGA	0.99
pmiioppkqrvw.pw	DGA	0.98
brstpvrtkcpp.com	DGA	0.97
htschinwcghk.com	DGA	0.86

DGA (False Negatives)

Domain	Verdict	Confidence
perhapstogether.net	DGA	0.52
partydifference.net	DGA	0.58
summerdifference.net	DGA	0.53
womandifference.net	DGA	0.53
gentlemanalthough.net	DGA	0.52
experienceevery.net	Benign	0.52
beginevery.net	Benign	0.76
partyperiod.net	Benign	0.69
smokesingle.net	Benign	0.69
mountainmatter.net	Benign	0.53
mountainapple.net	Benign	0.73

DGA (False Negatives)

NXDOMAIN

- Thousands of the DGA domains queries but only few resolve
- Normally typos, copy paste errors, browser prefetch. Less than 5% of the traffic

Malware Family	NXDOMAIN ratio
Cryptolocker	2.07
Nivdort	13.58
Telsacrypt	14.38

```
nxdomains_by_src = rdd.filter(rcode_is_nxdomain).map((src_ip, qtype))
mean = numpy.mean(nxdomains_by_src.countByKey().values())
outliers = nxdomains_by_src.filter(num_nx_domains > mean)
```

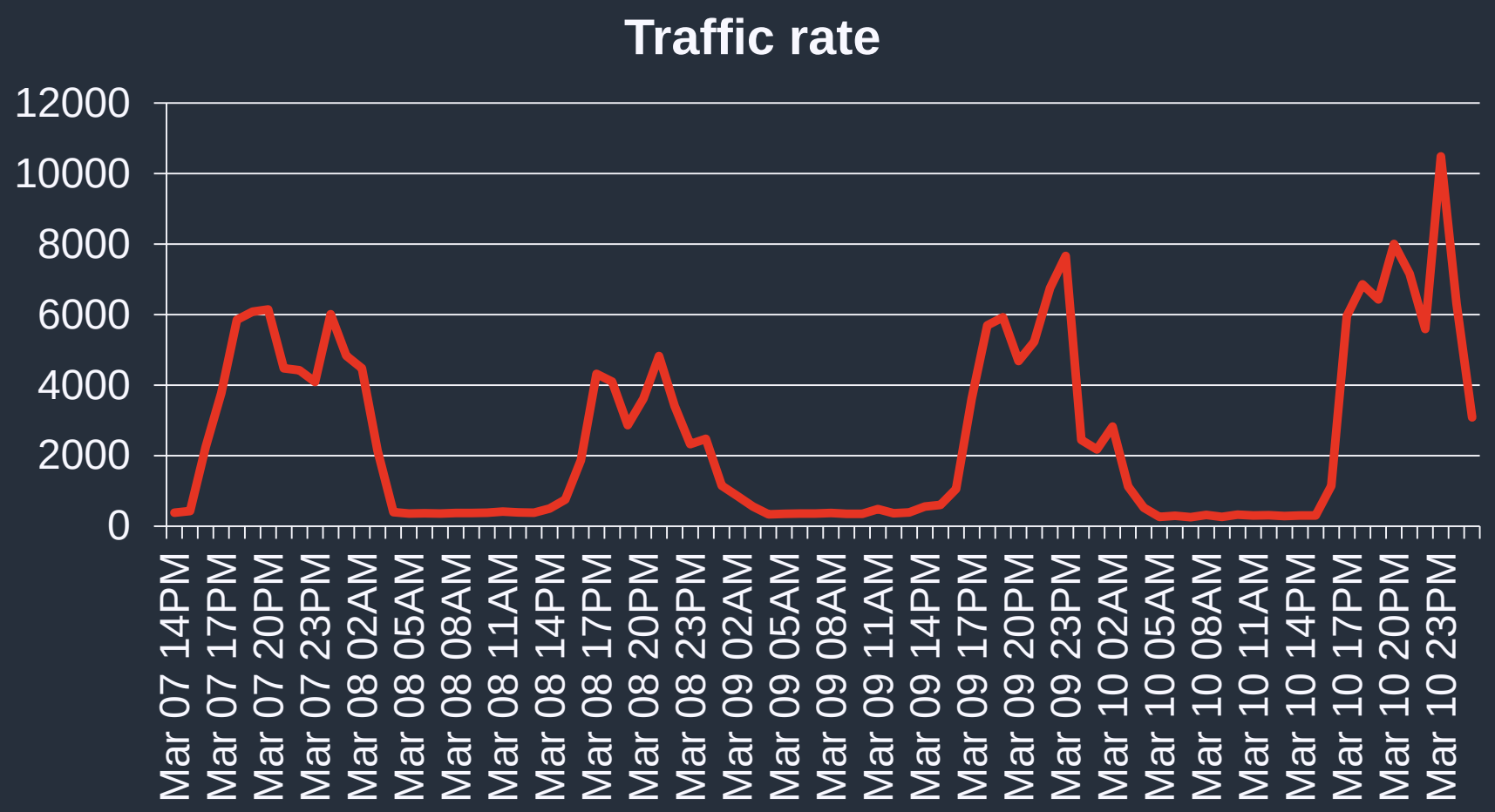
False Positives

Domain	Class	Probability
qetdjnndqo.c*****1.org.	DGA	0.83
mjhhofjsdrsulcn.c*****1.org	DGA	0.96
hicbaxevoldlszl.c*****1.org	DGA	0.96
bchbnajexhspfrq.c*****1.org	DGA	0.97
mbgmajnvrvyn.c*****1.org	DGA	0.96
nlbvxhfomxx.c*****1.org	DGA	0.95

- DGA like domains
- Most of them NXDOMAINs
- WHOIS privacy proxy

Chrome DNS wildcard detection!

Periodicity



Periodicity

- Continuous traffic generated by the OS and background services
- For example, software update check, keep alive, content refresh

```
timestamps = [t1, t2, t3, t4…..tn]
delta_ts = [(t2,-t1), (t3-t2), (t4-t3)...(tn-tn-1)]
mean, tolerance = numpy.mean(delta_ts), numpy.std(delta_ts)*0.5
num_periodic_requests = sum([mean - tolerance < dts < mean + tolerance for dts in delta_ts])
prob = num_periodic_requests/len(delta_ts)
```

Periodicity (benign)

Domain	Inter-request time	Probability
e673.e9.akamaiedge.net	530.5	0.99
itunes-cdn.itunes-apple.com.akadns.net	1190.0	0.97
teredo.ipv6.microsoft.com.nsatc.net	919.0	0.95
ds-comet.yahoo.g01.yahoodns.net	360.0	0.88
itunes.apple.com.edgekey.net	595.0	0.98

Hosted on HA, load balanced networks that are usually on our whitelist

Periodicity (malicious)

Cryptlocker (~953 sec)	Probability
vobrbjlloae.fr	0.98
www.tabi104.net	0.84
wtjawjv.nl	0.96
ojqya.pw	0.98
netvegonhi.nl	0.98

Nivdort family (~1892 sec)	Probability
desireproduce.net	0.70
partyorderly.net	0.89
stillaction.net	0.87
desireoclock.net	0.73
fightbattle.net	0.77

Phishing Detection

Real website	Fake site
facebook.com	facebookc.om
malware.com	rnalware.com
apple.com	applesoftupdate.com
paypal.com	paypal.com.user.accounts.lwproductions.net

- *"Edit distance : number of operations like removal, insertion or substitution of characters that converts one string to the other"*
- Longest common substring: use a suffix tree for O(n)

```
type1 = rdd.filter([edit_distance(get_rname, domain) <= 2 for domain in alexa_top1k])
type2 = rdd.filter(len(lcs(get_rname, domain))/len(domain) > 0.8 for domain in alexa_top1k])
```

Next Steps

- Validate outliers
  - New or consistent behavior?
  - How many hosts?
  - How many models triggered
- Identify the user(s)/process generating the traffic, assess maliciousness
- If malicious, kick off incident response process

One more thing

- Every network is different, find out what's normal for yours
- Maintain a list of newly observed domains in your network
- Segment your network by the source of outliers

Hunting on the Host

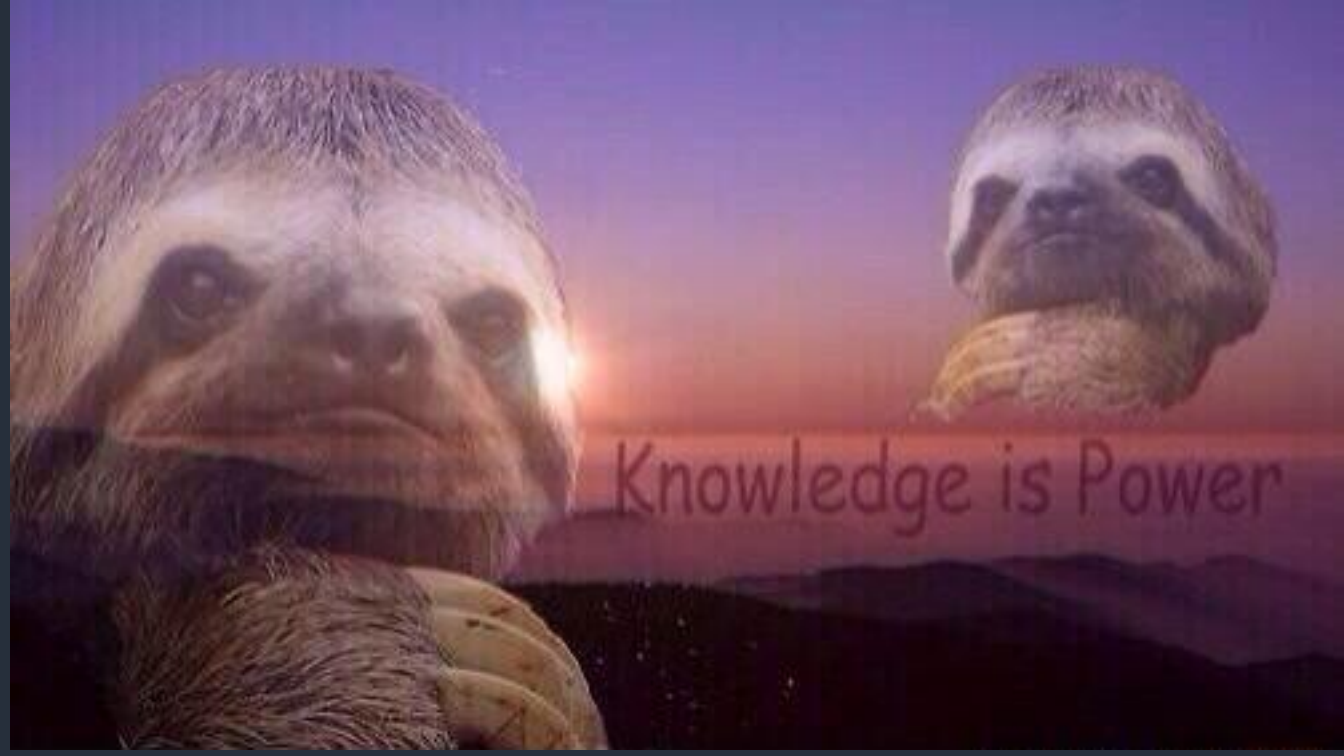
…on the cheap

General idea

- You have lots of hosts
  - And, they are somewhat homogenous
- Look for outliers and things that don’t make sense, investigate
  - Could be an application only one person is using
  - Could be malware
- Many things to look at
  - Processes
  - Network connections and listening ports
  - Filesystem
  - User logs
  - Autoruns
  - (There’s more…you have to choose what to focus on)

Scenarios

- Hunting with (open source) intelligence
  - Consume threat intelligence
  - Deploy remote Yara scan
- Hunting with zero intelligence
  - Collect specific data from all your hosts
  - Look for anomalies and outliers



Hunting with Intelligence

…on the cheap

Hunting with Intelligence

- Get Intel
  - IOC?
  - Hash?
  - TTP?
  - Filename?
- Apply Intel
  - Powershell + Yara!
- Remediate
  - Hope you have a remediation process…

Consuming Open Source Intelligence

- AlienVault
- IOCBucket
- Abuse.ch
- Blocklist.de
- EmergingThreats
- VirusTotal
- Malwr

YARA

- Apply standardized binary patterns + sequences to identify badness in a binary
- Grep on crack
- Scans files and memory
- Free signatures for tools used by bad guys targeting your vertical
  - Signatures are brittle ☹
  - But if well written, low false positive rate
  - And it's FREE ☺
- Value? This will tell you if a known bad file is on a given host

https://plusvic.github.io/yara/

Example Yara Rule

- Rule for Mimikatz (tool for dumping plaintext passwords)
  - Used by red teamers and APT groups alike
- https://github.com/gentilkiwi/mimikatz/blob/master/kiwi_passwords.yar

```
rule mimikatz
{
        meta:
                description              = "mimikatz"
                author                   = "Benjamin DELPY (gentilkiwi)"
                tool_author              = "Benjamin DELPY (gentilkiwi)"

        strings:
                $exe_x86_1               = { 89 71 04 89 [0-3] 30 8d 04 bd }
                $exe_x86_2               = { 89 79 04 89 [0-3] 38 8d 04 b5 }

                $exe_x64_1               = { 4c 03 d8 49 [0-3] 8b 03 48 89 }
                $exe_x64_2               = { 4c 8b df 49 [0-3] c1 e3 04 48 [0-3] 8b cb 4c 03 [0-3] d8 }

                $dll_1                   = { c7 0? 00 00 01 00 [4-14] c7 0? 01 00 00 00 }
                $dll_2                   = { c7 0? 10 02 00 00 ?? 89 4? }

                $sys_x86                 = { a0 00 00 00 24 02 00 00 40 00 00 00 [0-4] b8 00 00 00 6c 02 00 00 40 00 00 00 }
                $sys_x64                 = { 88 01 00 00 3c 04 00 00 40 00 00 00 [0-4] e8 02 00 00 f8 02 00 00 40 00 00 00 }
```

Remote Yara Scan

Leverage Powershell to remotely run a Yara scan with a pre-defined rule set on a given directory

- Transfer Yara binary to target machine w/ native Windows functionality
  PS> copy yara.exe \\TARGET-HOST\C$\TEMP\yara.exe
- Transfer rules
  PS> copy rules.yara \\TARGET-HOST\C$\TEMP\rules.yara
- Execute scan w/ Invoke-Command
  PS> Invoke-Command -ComputerName TARGET -ScriptBlock { c:\TEMP\yara.exe c:\TEMP\rules.yara c:\targetdir } -credential USER

So what?

- You should look for emergent known bad across your network
  - Yara is a great way to find known bads and kick off the remediation process
- Sadly, malware changes rapidly so this is necessary but not sufficient…

https://github.com/Yara-Rules/rule

Hunting with no Intelligence

…on the cheap

Autoruns

- There are lots of places to look on hosts for oddities and outliers
- Bad guys love to stick around on a box – persistence
  - Makes it harder to get rid of an infection
  - So, we'll focus our zero intelligence hunting on Autoruns
- Where are the autoruns?
  - Registry run keys
  - Services
  - Drivers
  - Browser add-ons
  - Tons of other crafty stuff
    - Over 100 locations – thanks Windows!
    - Thankfully, free tools can help you out

Does this really work

- Yup
- Autoruns should be relatively consistent across the network
  - Assuming network is somewhat homogenous and locked down
- Anomalous autoruns could indicate badness

Sysinternals autoruns

- Awesome tool from Microsoft
- Pulls most autorun items on a Windows system
- Hashes them for you
- Can submit them to VirusTotal for you

Hash Autorun Items to find Known Malware

Leverage Powershell to remotely execute Sysinternals "Autorunsc.exe" to collect autorun items via the command line, submit to VT

- Transfer Autoruns binary and required DLL to target machine w/ native Windows functionality

```
PS> copy autorunsc.exe \\TARGET-HOST\C$\TEMP\autorunsc.exe
PS> copy msvcr100.dll \\TARGET-HOST\C$\TEMP\msvcr100.dll
```

- Execute program w/ Invoke-Command (w/ optional output)

```
PS> Invoke-Command -ComputerName TARGET -ScriptBlock {
c:\TEMP\autorunsc.exe –a (??) –h (>> c:\TEMP\autoruns-output.txt) } -credential
USER
```

- Collect output

```
PS> copy \\TARGET-HOST\C$\TEMP\autoruns-output.txt c:\directory
```

Hash Autorun Items to find Known Malware (2)

- Submit all autorun hashes to VirusTotal
- Anything that returns a positive malware hit in VT should be investigated
- This can be done inline with the Sysinternals Autoruns tool
- Or you can build something yourself easily with the VirusTotal API

```
>>> import simplejson
>>> import urllib
>>> import urllib2
>>> url = "https://www.virustotal.com/vtapi/v2/file/report"
>>> parameters = {"resource": "99017f6eebbac24f351415dd410d522d",
...               "apikey": "-- YOUR API KEY --"}
>>> data = urllib.urlencode(parameters)
>>> req = urllib2.Request(url, data)
>>> response = urllib2.urlopen(req)
>>> json = response.read()
>>> print json
{
 "response_code": 1,
 "verbose_msg": "Scan finished, scan information embedded in this object",
```

Stack the Data to Identify Anomalies

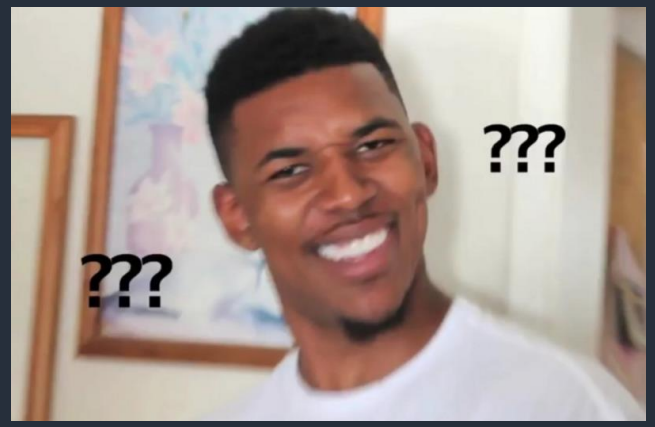
- Pull hashes of all autorun items (see previous)
- Map autorun hashes as HOST:HASH

```
$ cat hash-map.txt
10.54.23.4:0dbca2da61a0a46e41095b92434d16974351f92ae0268eafae67a8a2d26c4449
10.54.23.4:fcaee53875a28ed570d4e1b12610ec9503cfcca26c7964df304390e04e368264
10.54.23.4:0dbca2da61a0a46e41095b92434d16974351f92ae0268eafae67a8a2d26c4449
10.54.23.4:eb0ed2b57db1fee056526e065af4d874b8f2dfec0fad14defbb61184ce32d4cf
10.54.23.4:873e697cc9f3a0d85346befd537905c8642654a8be836d9b3fa41826a2ef729f
10.54.23.4:111655197188bbfe1d7b914d367281002795033638cfce67635dd597f8c31772
10.54.23.4:57359b3f029a3590905d81a3c99d4a7e784fdc33b4f052c95b4d24c41f390312
10.54.23.4:7ca6c3b0cc309f6e0a7ceabec98eb97874e649b155493b52aee90cd06f1acf46
10.54.23.5:111655197188bbfe1d7b914d367281002795033638cfce67635dd597f8c31772
10.54.23.5:eb0ed2b57db1fee056526e065af4d874b8f2dfec0fad14defbb61184ce32d4cf
10.54.23.5:57359b3f029a3590905d81a3c99d4a7e784fdc33b4f052c95b4d24c41f390312
10.54.23.5:7ca6c3b0cc309f6e0a7ceabec98eb97874e649b155493b52aee90cd06f1acf46
...
```

Stack the data to identify anomalies (2)

- Delineate output by colon (:)
  # cat hash-map.txt | cut -d':'-f2 > hashes.txt
- Reduce by amount of occurrences

```
$ cat hashes.txt | sort | uniq -c | sort -n | tac
42 fcaee53875a28ed570d4e1b12610ec9503cfcca26c7964df304390e04e368264
42 eb0ed2b57db1fee056526e065af4d874b8f2dfec0fad14defbb61184ce32d4cf
42 873e697cc9f3a0d85346befd537905c8642654a8be836d9b3fa41826a2ef729f
42 7d0398d3cdd1de1e004fb26811107ed168e54803c4b9fd6cdd248c84081c9b49
42 7ca6c3b0cc309f6e0a7ceabec98eb97874e649b155493b52aee90cd06f1acf46
42 62b0f613fc4fb0754494bc0d035a0a3162c0ae8a81f0279ccfcf5c69048716ce
42 57359b3f029a3590905d81a3c99d4a7e784fdc33b4f052c95b4d24c41f390312
42 18b553d24823abc903c16993a2072cefe4768f8e9d14a5b4781f1b58e0c9b667
42 111655197188bbfe1d7b914d367281002795033638cfce67635dd597f8c31772
42 0dbca2da61a0a46e41095b92434d16974351f92ae0268eafae67a8a2d26c4449
42 0b85a8f2e728ff357e3e5058e18203dd355af15956a991327d3746e2b5c5fc95
1 9f7537bf60aa99f7654b8278ed7b2ab0051c1ee3268d56536846a46a333b87cd
1 20d550d4bd3fd45e1788847574fa1cc340f2bf910094b75de4f237bb643477f6
```



Stack the data to identify anomalies (2)

- Reference the hash map from initial collection

$ grep "20d550d4bd3fd45e1788847574fa1cc340f2bf910094b75de4f237bb643477f6" hash-map.txt
10.54.23.77: 20d550d4bd3fd45e1788847574fa1cc340f2bf910094b75de4f237bb643477f6

Backdoor'ed version of Vmware tools

```
      IMPHASH:   D0058544E4588B1B2290B7F4D830EB0A

HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
   VMware User Process
      "C:\Program Files\VMware\VMware Tools\vmtoolsd.exe" -n vmusr
      VMware Tools Core Service
      VMware, Inc.
      9.10.5.49873
      c:\program files\vmware\vmware tools\vmtoolsd.exe
      8/13/2015 6:10 AM
      MD5:       F653B8FB895CB337BB0244122AA011AE
      SHA1:      BB8653DFF5BB5D05159273DBDBFDD227DB1960C7
      PESHA1:    C47F1DCF6F2B96C79081F5FE93E98877ACF4AE2D
      SHA256:    9C8B618F516D63A6ECD515365C20539E4EB31E3BE9B34B0C3E7DE5A6018CF017
      PESHA256:  1E4593AB032EA1355300C7375B98516DCFE9692004CD96A55E01489FBA4844A1
      IMPHASH:   A159F8FDD653064D9ED8EB7F31C7C1B4
```

Extra Credit

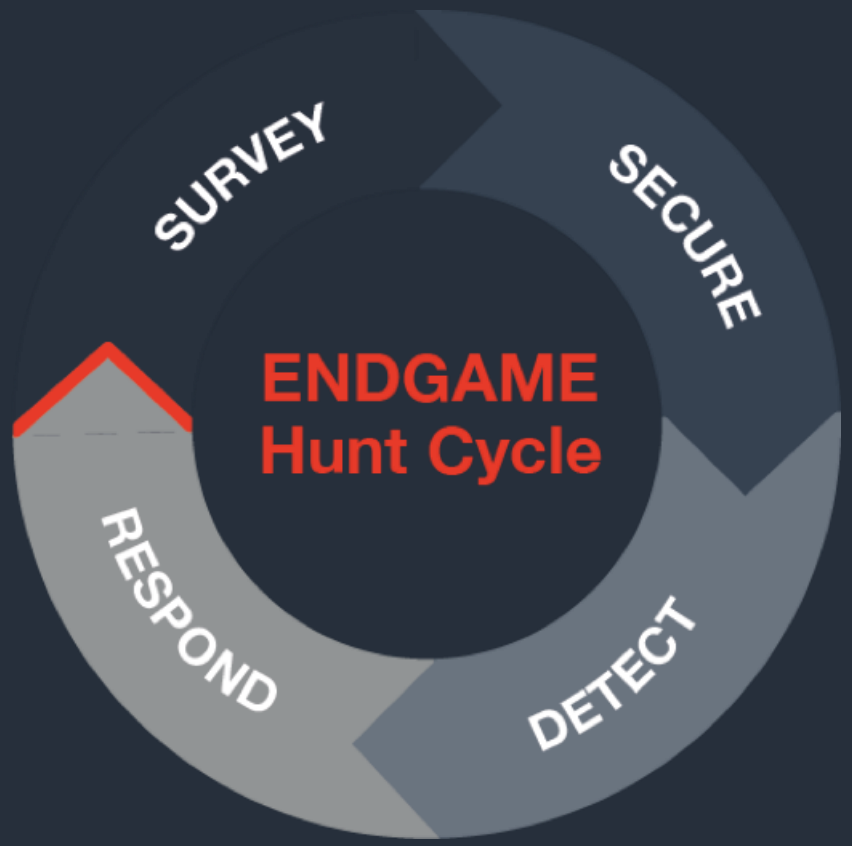
- Dump all of the autoruns from the entire organization into an Elasticsearch cluster
- Collect data periodically
- Analyze changes over time

Conclusion

- Understand your network and adversary tactics
- Reach out and check for badness on the network
- Look at host anomalies to identify badness on your hosts
- Once you find badness, kick it to your remediation process
- You can do all this very cheap
  - No signatures
  - No IOCs
  - JUST PURE HUNTING GOODNESS

Endgame Hunt Cycle

- **Recon** of internal network
- **Identification** of assets to protect
- **Gather** data



- **Implement** mitigation techniques
- **Prevent** adversary techniques
- **Protect** uncompromised systems

- **Respond** intelligently with surgical actions
- **Act** at scale to evict the adversary
- **Report** on the hunt

- **Analyze** collected data for outliers
- **Discover** new indicators of compromise
- **Pivot** to determine the full extent of the breach

Thank You.

Lunch and Learn, Wednesday April 12 at 12:05

Think Offense: Hunt Smarter, Live Low

Mike Nichols, Principal Product manager